DigiLocker Data Privacy & Cybersecurity Audit

- **Authentication & Access Control**
  - Login and verification
    - Observed controls
      - Mobile-number login; QR-code and Aadhaar/VID alternatives are also provided.
      - Verification supports TOTP through the DigiLocker mobile app and SMS OTP.
      - Successful OTP verification opens the authenticated dashboard.
      - Evidence: Observed (O).
  - Sensitive-service gating
    - Aadhaar verification
      - Dashboard and modal indicate Aadhaar verification is required for sensitive services.
      - This acts as a step-up or eligibility gate beyond ordinary authenticated access.
      - Aadhaar-linking request included consent=Y and a UID-like parameter; the Aadhaar/VID value is not reproduced.
      - Server returned HTTP 200 with application error 515 for invalid Aadhaar/VID; no successful OTP issuance was observed.
      - Evidence: Observed (O).
  - Tokens and sessions
    - Observed controls
      - Authenticated API request included a custom jtoken header containing a JWT.
      - JWT header advertised RS256 and typ=JWT; server-side signature validation was not independently tested.
      - Claims included iat, exp, aud, iss, and jti; timestamps indicated approximately 30-minute validity.
      - A device-security-id header was present; its value is redacted.
      - Evidence: Observed (O).
  - Unverified controls and residual risk
    - Not verified
      - Exact TOTP algorithm, OTP retry/rate limiting, and replay protection.
      - Token revocation, server-side session invalidation, and reuse of old tokens.
      - Account takeover and token theft/replay remain residual risks.
      - Evidence: Not Verified (NV).
  - Assessment and actions
    - Strengths and recommendations
      - Multiple authentication methods are exposed; short-lived signed JWTs limit a stolen token's useful lifetime.
      - Risk rating: Info / Positive.
      - Verify OTP expiry, throttling, maximum attempts, lockout or step-up behavior, and replay resistance.
      - Verify token expiry, revocation, authorization, issuer, audience, and token identifiers server-side.
      - Keep authentication and session secrets out of URLs, logs, and client-side errors.
- **API & Browser Security**
  - API communication
    - Issued-documents API
      - POST to https://ids.digilocker.gov.in/fast/api/2.0/issueddocs.
      - Request included redacted jtoken and device-security-id headers; captured body was empty.
      - Origin was https://www.digilocker.gov.in; response was HTTP 404 twice.
      - Cache-Control included no-store, no-cache, must-revalidate, and private.
      - The 404 is an observation, not evidence of a vulnerability; possible explanations include route/version mismatch, unavailable feature, application state, deprecated route, or intentional behavior.
      - Risk rating: Low / Unclear; review monitoring and frontend/backend route alignment.
    - Aadhaar-linking API
      - HTTPS POST to api-delhi-accounts-10001.digitallocker.gov.in/linkaadhaar/send_otp.
      - Redacted jtoken and device-security-id headers were present.
      - CORS allowed the DigiLocker web origin.
      - Response was HTTP 200 with application-level error 515; no successful OTP was observed.
      - Evidence: Observed (O).
  - Browser security headers
    - Observed protections
      - HSTS with includeSubDomains and preload on the ids API.
      - CSP present; captured main web application policy permitted unsafe-eval.
      - X-Content-Type-Options: nosniff.
      - Referrer-Policy: strict-origin-when-cross-origin.
      - CORS allowed the DigiLocker web origin; it does not replace server-side authorization.
      - COOP same-origin, COEP require-corp, and CORP same-origin.
      - Permissions-Policy disabled several browser capabilities.
      - X-Frame-Options: SAMEORIGIN and restrictive no-store/no-cache directives observed.
      - No exploitable XSS was tested or established.
    - Assessment and actions
      - Multiple modern browser/API security headers and restricted CORS are positive controls.
      - CSP unsafe-eval weakens policy strictness; risk rating: Low–Medium.
      - Remove unsafe-eval where technically feasible and move toward stricter CSP.
      - Maintain explicit CORS allowlists, HSTS, and browser security headers; regression-test after frontend releases.
  - System and trust architecture
    - Observed and documented
      - HAR showed multiple DigiLocker/API Setu-related hosts: web UI, identity/document API, account/Aadhaar API, Drive service, and static/media resources.
      - Public architecture documentation describes modular microservices and an API gateway for ecosystem integrations.
      - HAR does not independently map the complete backend.
      - Evidence: Observed (O) for hostnames; Officially Documented (D) for public architecture.
- **Data Privacy & Handling**
  - Data categories
    - Information processed or potentially processed
      - Identity and authentication data: mobile number and authentication events; OTP/TOTP-related processing.
      - Aadhaar/VID and verification data when Aadhaar verification is performed; high-sensitivity identity processing.
      - Issued documents and associated metadata.
      - Account/session identifiers and access activity.
      - IP, browser, and request information may be processed for security or operations; exact retention was not verified.
      - Issuer terms describe document access as dependent on explicit user consent.
      - No Aadhaar/VID value is reproduced.
  - Privacy controls and gaps
    - Observations and recommendations
      - Apply data minimization to Aadhaar workflows and explain the purpose and necessity of each Aadhaar-dependent service.
      - Keep document sharing explicitly consent-based, auditable, and revocable where supported by the service design.
      - consent=Y was observed in the Aadhaar-linking request.
      - No-store/no-cache was observed for a captured API response.
      - Exact operational-metadata retention was not verified.
      - Storage-encryption algorithms and key-management mechanisms were not visible; do not assume AES, RSA, HSM, or other specifics without evidence.
      - Obtain approved technical documentation for storage encryption and key management.
  - Issuer privacy governance
    - Officially documented terms
      - Issuer terms cover onboarding and participation for digitally issued documents; they are not a complete citizen privacy policy.
      - Issuers are responsible for document content and validity.
      - Document access is described as consent-based and dependent on explicit user consent.
      - Terms reference PKI for digital signing and verification.
      - Technical, organizational, and administrative safeguards are required to protect personal-data confidentiality, integrity, and security.
      - Issuers must notify DigiLocker in writing within 24 hours of becoming aware of an actual or suspected personal-data breach.
      - NeGD may suspend or block API access for non-compliance, security concerns, or regulatory directions.
      - Affiliate integration requires prior written approval; issuers remain liable for use of issued APIs and credentials.
      - Evidence: Officially Documented (D).
- **Document Integrity & PKI**
  - Document authenticity
    - Documented requirements
      - Issuer terms require electronically issued documents to be digitally signed and digitally verifiable.
      - Terms explicitly reference PKI for signing and verification.
      - Evidence: Officially Documented (D).
  - Unverified implementation details
    - Not verified
      - Exact signature algorithm, certificate chain, hash algorithm, and key size.
      - Blockchain use was not established; do not claim blockchain without official evidence.
      - Evidence: Not Verified (NV).
  - Recommendations
    - Assurance
      - Use digital signatures and PKI for document authenticity and integrity.
      - Provide verification guidance to users and requesters.
      - Verify a permitted sample document signature and certificate chain.
- **Governance & Issuer Responsibilities**
  - Issuer participation and API governance
    - Documented responsibilities
      - Successful onboarding allows issuers to publish and distribute electronically signed, digitally verifiable documents.
      - DigiLocker acts as a secure digital/transmission platform; issuers remain responsible for document content and validity.
      - Issuer APIs are for authentic-source document issuance.
      - Every issuing endpoint must map to a verified use case approved by NeGD.
      - NeGD may suspend or block API access for non-compliance, security concerns, or regulatory directions.
      - Affiliate integration requires prior written approval; issuers remain liable for API and credential use.
      - Evidence: Officially Documented (D).
  - Incident response and safeguards
    - Requirements and recommendations
      - Issuers must notify DigiLocker in writing within 24 hours after awareness of an actual or suspected personal-data breach.
      - Maintain documented breach-notification and incident-response procedures across issuers and platform operators.
      - Continuously monitor issuer APIs; enforce approved-use-case mapping, credential protection, and rapid suspension procedures.
      - Maintain technical, organizational, and administrative safeguards for personal-data confidentiality, integrity, and security.
- **Threat Model**
  - Account and API access
    - Threats and controls
      - Account takeover could enable unauthorized document access; relevant controls include TOTP/SMS OTP and JWT sessions.
      - Token theft or replay could enable unauthorized API access; relevant controls include JWT expiry and HTTPS.
      - OTP throttling, replay protection, token revocation, and token binding remain unverified.
  - Browser and data exposure
    - Threats and controls
      - Cross-origin abuse could enable unauthorized browser API reads; restricted CORS is a positive observed control.
      - Clickjacking could deceive users or trigger unauthorized actions; X-Frame-Options/CSP provide observed hardening.
      - XSS or script injection could compromise sessions or data; CSP provides defense in depth, but unsafe-eval weakens strictness.
      - Sensitive-data caching could expose data locally or through intermediaries; no-store/no-cache is a positive control for the captured API.
  - Issuer and document risks
    - Threats and controls
      - Malicious or incorrect issuer data could produce invalid document content; issuer responsibility and signatures are documented controls.
      - Issuer API misuse could enable unauthorized issuance or access; approved-use-case mapping is documented.
      - Issuer data breaches could compromise privacy; a 24-hour notification requirement is documented.
- **Findings & Risk Ratings**
  - Positive and observed findings
    - Authentication and API controls
      - F-01: Multiple authentication methods, including TOTP and SMS OTP — Info / Positive.
      - F-02: JWT in jtoken header; RS256 advertised and approximately 30-minute lifetime — Info / Positive.
      - F-03: Multiple modern browser/API security headers — Info / Positive.
      - F-04: CORS restricted to DigiLocker web origin — Info / Positive.
      - F-05: Aadhaar verification gate for sensitive services — Security / Privacy Control.
      - Recommendations include retaining controls, verifying authentication protections, and applying Aadhaar data minimization.
  - Observations and vulnerabilities
    - Risk and follow-up
      - F-06 / V6: Issued-documents endpoint returned HTTP 404 twice — Low / Unclear; review route/version alignment and monitoring. A 404 alone is not a security vulnerability.
      - V1: CSP permits unsafe-eval — Low–Medium; remove where technically feasible.
      - V2: OTP/TOTP rate limiting, maximum retries, and replay protection — Unknown / Not Verified; verify and document controls.
      - V3: Token revocation and server-side session invalidation — Unknown / Not Verified; test logout, expiry, revocation, and old-token reuse in an authorized environment.
      - V4: Storage encryption and key management — Unknown / Not Verified; obtain approved technical documentation.
      - V5: Digital-signature and certificate-chain implementation — Unknown / Not Verified; verify a permitted sample.
      - V7: Blockchain use not established — N/A / Not Verified; do not claim blockchain without official evidence.
- **Evidence & Audit Scope**
  - Evidence classifications
    - Meaning
      - O — Observed directly in screenshots or captured browser traffic.
      - D — Officially Documented in DigiLocker documentation or terms.
      - I — Inferred from evidence; not independently proven.
      - NV — Not Verified within this audit scope.
  - Scope caveats
    - Assurance limits
      - Some authentication, session, storage-encryption, and document-signature controls were not verified.
      - The audit did not establish complete backend architecture or test for exploitable XSS.
      - Use periodic independent security audits and authorization testing.
      - This academic audit is not a substitute for professional penetration testing.

Boardmix